



File No.: EXP202202155

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: ***UNION.1 (hereinafter, the claimant), on 14/12/2021, filed a complaint with the Spanish Agency for Data Protection. The complaint is directed against the entity AYUNTAMIENTO DE GIJÓN, with NIF P3302400A (hereinafter, the respondent or AYUNTAMIENTO or AYUNTAMIENTO DE GIJÓN), and within the AYUNTAMIENTO against whoever corresponds in the Department of Citizen Security, Local Police, and Mayor's Office, as well as against any person involved in the events (specifically mentioning one official). The reasons on which the complaint is based are as follows: The claimant presents a complaint regarding the leak and dissemination through WhatsApp and social media of a document submitted to the Electronic Registry of the AYUNTAMIENTO DE GIJÓN, dated 20/01/2021, which informed about the possible commission of an infringement of the disciplinary regime of the Local Police.

It adds that on 19/02/2021, it submitted a new document to the same Ayuntamiento to communicate that unlawful dissemination of the document from 20/01/2021, urging an investigation into the security breach and the clarification of responsibilities.

According to the claimant, in response to the previous document, by resolution dated 30/08/2021, the respondent acknowledges unauthorized access to the registration entry and the leak and dissemination thereof, as well as treatments such as habitual, general, or indiscriminate access to the entries of the incoming register, which do not relate to the basis of legality and purposes contained in the inventory of activities; and resolves only to adopt a series of measures for the future ("implementing all of this, especially regarding the Local Police").

Furthermore, the claimant warns that there is no record that the AYUNTAMIENTO DE GIJÓN has notified this Agency or the affected parties about the security breach, nor that it has adopted any measures, "despite the seriousness of the matter, as it affects citizens in general and unions in particular, since it is acknowledged that union activity is being monitored..."

It considers that the respondent has not guaranteed confidentiality, has violated the duty of secrecy, and the rules regarding communications of security breaches.

Along with the complaint, it submits the documents presented by the claimant to the respondent and the response issued by the latter:

a) Document submitted by the claimant to the Electronic Registry of the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/19

TOWN HALL on the date 20/01/2021, informing about a possible infringement of the disciplinary regime of the Local Police. In this document, in addition to the factual circumstances that, in the opinion of the claiming party, determine the possible disciplinary infringement, the details regarding the name and surname of the possible infringer and the details of the representative of the claiming party, including name, surname, ID number, and position held in the organization of the claiming party, are included.

b) Document submitted to the Electronic Registry of the responding party on the date 19/02/2021 reporting a leak/dissemination of the document mentioned in section a) above.

In the third point of this document, the claiming party states that "We have become aware that the aforementioned document is being disseminated through the Whatsapp platform, across various groups (...).

In this document, the claiming party requests that "the appropriate inquiries be made regarding the security breach that occurred in the departments that were supposed to safeguard the aforementioned

document. Furthermore, the illegitimate accesses to the document as well as to the individuals who disseminated it should be verified, holding accountable those responsible.”

c) Notification dated 30/08/2021 by which the representative of the claiming party is informed of the resolution issued on the same date by the TOWN HALL OF GIJÓN (Resolution of the Mayor) regarding the complaint dated 19/02/2021, mentioned in section b) above.

In its third and fourth points of the Background Facts, reference is made to the content of the report issued regarding this matter by the Information Systems Service: “All personnel from the Citizen Relations Service have access to the General Registry to process incoming requests to the units responsible for their processing, access that is essential to fulfill their duties.

At the moment a document enters the organization through the Registry, it is possible to trace its use through corporate applications, but if the document is extracted (to be sent by other electronic means or printed), it is no longer possible to track it.

On the other hand, it has also been verified through the printing management system if a document with a name identical or similar to the original document has been printed, with a negative result.”

In the fourth point, the following is indicated:

“From the aforementioned report, a series of accesses by municipal personnel to the indicated registry entry are deduced, which, due to their presumed knowledge and alleged dissemination, are cited successively as recorded in the referred file, highlighting the individuals –(...), in what is relevant for the clarification of facts and other concurrent circumstances, who accessed said entry annotation for various reasons, and according to each declarant, due to:

- That remote access permission is granted from the workstation to the common module of the general registry book of incoming documents of the Town Hall.
- That these are justified accesses for the ordinary performance of the tasks of the work positions or because all entries in the registry are routinely reviewed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/19

of entry of the City Council; (...), with the aim of addressing union and labor matters that may affect them in their capacity as affiliates and interested parties.

Regarding the method of access, the declarants stated that they have a user account—except for one case, which also lacked computer equipment at their disposal—with their own password that is not shared, for access to the computer applications for entry registration and file management; however, it has been detected that in two workplaces, shared use with other personnel occurs, which would justify that their user profile appears in the access audit but they claim not to have personally performed such action. In general, none of them are aware of any incidents related to a possible identity theft or unauthorized access to their accounts.

In relation to the direct knowledge of the content of the document subject to the complaint, they either deny it or attribute it to a simple access error to the entry record of their profile in the audit log.

However, they claim to have had indirect knowledge, either verbally or through a WhatsApp group called “***GROUP.1”—although one declarant denies that anything regarding this was published in this network—which, according to its administrator—(name and surname indicated), (...)—is of a recreational nature, has a total of 81 members, (...), and regarding which he “does not exercise any control over what is published,” nor does he read or participate and “deletes the messages he receives.”

Regarding the dissemination of the document in question, the appearing parties deny having carried it out; only in one case has it been stated that the text was printed at the request of a superior—***POSITION.1—to whom it was delivered; in another, it is stated that the news of the registration presentation was disseminated in another WhatsApp group ***GROUP.2.

Finally, concerning the consequences of such dissemination, either there is no knowledge, or there is awareness of a petition for signatures in support of the person to whom direct reference was made in the repeated document of January 21, for its withdrawal or individual presentation, (...), or to “hold a

general assembly.”

On the other hand, in the fifth point of the same Background Facts, the information provided to the investigations by the representative of the complaining party is detailed:

“It is noteworthy that, in light of the results achieved in the instruction of the file, the complainant was required to specify some circumstances of the investigated facts, stating in his appearance that, regarding the document registered on January 20, 2021, he first became aware of its leak on February 14, 2021, when he received a message on his personal WhatsApp (...), which he identifies as... (name and surname indicated), where he “expresses his anger at the presentation of the aforementioned document, to which he adds insults and threats,” providing a screenshot as evidence of this.

Furthermore, the complainant presented evidence of the dissemination of the indicated document in the WhatsApp group—referred to as “***GROUP.2”—that he has with his work shift colleagues (...), administered by... (name and surname indicated), and where “one of the members... (name and surname indicated) after the deletion of several written and removed messages contributed the entire document in pdf format at 22:16” and that “it can be observed that the document provided is a forward.”

Regarding this last point, it should be noted that the aforementioned... (initials of the first name and surname), in a statement taken at a later date, states that he became aware of the subject of the present file in the group “***GROUP.1” and “that he remembers that in that group a message was posted saying that the colleague... (name indicated) had filed a complaint by registration that he had been insulted or given a nickname during a roll call in which he was not present. And that the news he saw in that group he passed to another group called “***GROUP.2,” not recalling that it was a document, only asking if they knew anything about it and nothing more.”

On the other hand, continuing with the testimony of the complainant, in this messaging group “***GROUP.2,” he also stated that, as he attests, “he had been able to access a screenshot of a conversation from WhatsApp coming from the group of “***GROUP.1.” The time of the screenshot is 4/19

from 20:00 to 20:05.”

Likewise, it adds that, on the indicated day of February 14, he received (...) “a forward of the conversation with... (name and surname indicated), where the pdf is displayed accompanied by the phrase ‘I did not send you anything’ and requesting support or help to have the aforementioned document of January 20, 2021, withdrawn”: it provides documentary justification of a screenshot where “in the image of the conversation it is evident that the pdf document comes from a forward again.” Finally, it also points out the aforementioned “signature collection organized (...)”, presenting the document that he has received with the same “where the withdrawal of the submitted document is requested.”

The above, also known by (...)... (initials of the name and first surname indicated), is ratified by him in a different statement made, also providing evidence of the actions of (name and first surname indicated) on February 14, “where in a threatening tone and in plural, he gives an ultimatum to withdraw the document submitted on January 20, 2021.”

And in the fifth point of the Legal Grounds, regarding the lawfulness of data processing (Article 6.1, letters c) and e), of the GDPR), it states:

“From this, it can be concluded that some of the treatments expressed in the Background, such as habitual, general, or indiscriminate access to the annotations of the entry register or for the exercise of supposed union rights, do not relate to the basis of lawfulness and purposes contained in the aforementioned inventory of activities.”

Finally, in the sixth point of the Legal Grounds of the aforementioned resolution, the measures that have been taken in relation to the causes that motivated the security incident are mentioned:

“In relation to the causes that motivated the security incident, the following measures have been taken, as stated in the report of the Information Systems Service mentioned at the beginning:

In the configuration of user accounts of the applications: for the user accounts involved in the security incident, associated permissions that should no longer be in place due to the change of the person’s

workplace or functions have been removed.

In the access configuration to the General Registry: the possibility of consulting the documents associated with all the entries in the general entry book of the City Council has been deactivated. This consultation option was associated with a significant number of people, who had requested it from 2015 to the present and who needed it to work correctly with the files under their responsibility. In this regard, it is not recorded that the measure of limiting generalized access to the common module of the entry register has affected the performance of the usual tasks of the positions under investigation.”

In accordance with the Background and Legal Grounds expressed, it is resolved to adopt the following measures, among others:

- Technical and organizational complementary measures and regulations that are appropriate, to minimize the possibility of similar incidents occurring again, regarding the way of onboarding, offboarding, and mobility of municipal personnel in the assignment of accounts, permissions, or access authorizations, revocation or deactivation of applications and IT and electronic resources, in accordance with the functions and tasks that they effectively perform in their positions within the organization.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/19

- . Regulatory, technical, and training measures deemed appropriate regarding the existence, creation, and use of messaging groups, social networks, or internal communication among municipal staff.

- . Forward the information to the Human Resources Management Service to inform them of the facts described in the Background, in case they constitute a disciplinary infringement or require additional preliminary investigation actions.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter LOPDGDD), the aforementioned complaint was forwarded to the party being complained against, so that they could analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the provisions established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on 25/02/2022, as noted in the acknowledgment of receipt in the file.

No response has been received to this forwarding letter.

THIRD: On 14/03/2022, in accordance with Article 65 of the LOPDGDD, the complaint submitted by the complainant was admitted for processing.

FOURTH: The General Subdirectorate of Data Inspection proceeded to carry out preliminary investigation actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD.

In response to the request made by the Inspection Services of the AEPD, the party being complained against provided the following information and documentation:

1. It declares that the resolution of the Mayor's Office dated 30/08/2021, already submitted by the complainant and whose content is noted in Background One, is reproduced.

2. It provides a copy of the report prepared by the Information Systems Service, dated 10/03/2021, detailing the causes that led to the incident that originated the complaint. From the content of this report, the following is noteworthy:

“In relation to the causes that motivated the security incident, the following measures have been taken:

1. In the configuration of user accounts for the applications: for the user accounts involved in the

security incident, associated permissions that should no longer be in place have been removed due to the change in the person's workplace or functions.

2. In the access configuration to the General Registry: the possibility of consulting documents associated with all incoming records of the general entry book of the Town Hall has been deactivated. This consultation option was associated with a number.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/19

important for individuals who had requested it from 2015 to the present and that was necessary to work correctly with the files under their jurisdiction.

To minimize the possibility of similar incidents occurring in the future, the following organizational measures are also proposed:

1. Establish a protocol for onboarding individuals in the organization, accurately recording the accesses, technical resources, and authorizations that need to be assigned to them.
2. Establish a protocol for offboarding individuals, which includes all measures to be adopted: deactivation of user accounts, email inboxes, revocation of electronic certificates, etc.
3. Establish a protocol for modifying individuals due to a change in position or functions, which precisely outlines the actions to be taken regarding their user accounts, access permissions to IT resources, etc. It should also include how to respond to informal requests for permissions made by the individuals themselves or their superiors.
3. A list of employees who had access to the document disseminated in the time frame between January 20, 2021, and February 14 of the following year is provided, supplied by the Information Systems Service. This list details the ID numbers of the individuals who accessed the document, their first and last names, and the department to which they belong (...).
4. Regarding the implementation of the measures agreed upon in the Mayor's resolution of 08/30/2021, it is reported that the hiring of an external service provider for the execution of those measures has been planned and that an Instruction from the Mayor regulating access and authorization for the use of municipal information systems is currently being drafted. It adds that training actions on security measures have been carried out and that there is no record of disciplinary actions related to the reported facts.
5. There are no risk analyses or impact assessments.
6. A copy of the Activity Record of Treatments related to the General Register is provided. In the sections "Category of recipients of the information" and "Description of the technical and organizational security measures for the information," the following is indicated, respectively:
 - "Municipal administrative bodies and other Public Administrations. Interested parties."
 - "They correspond to those provided in Annex II (Security Measures) of Royal Decree 3/2010, of January 8, which regulates the National Security Scheme in the field of Electronic Administration, according to internal regulations."

The complete text of the inventory is published at the web address <https://www.gijon.es/es/publicacion/es/inventario-del-registro-de-actividades-de-tratamiento-de-datos-personales>.

On this webpage, the identifying data of the responsible party (MUNICIPALITY) and DPD are listed:

FIFTH: On 02/08/2023, the Director of the Spanish Agency for Protection of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/19

Datos agreed to initiate sanctioning proceedings against the accused party, in accordance with the provisions of Articles 63 and 64 of the LPACAP, for the alleged violations of Articles 32 and 5.1.f) of the GDPR, classified under Articles 83.4.a) and 83.5.a) of the aforementioned GDPR, and categorized as serious and very serious for the purposes of prescription in Article 73.g) and Article 72.1.a) of the

LOPDGDD, respectively.

In the opening agreement, it was determined that the sanction that may correspond, without prejudice to what results from the instruction, would be a warning.

Furthermore, it was noted that the alleged violations, if confirmed, could lead to the imposition of measures, according to the aforementioned Article 58.2 d) of the GDPR.

SIXTH: Once the aforementioned opening agreement was notified in accordance with the rules established in the LPACAP, the accused party submitted a written statement of allegations requesting the dismissal of the proceedings based on the following considerations:

1. The initiation of the proceedings, two years after the events and more than twelve months after the complaint, when the AYUNTAMIENTO had already responded to the complainant through the resolution of 30/08/2021 and to the AEPD itself within the framework of its investigations, acknowledging the facts and detailing the measures to be applied to prevent their recurrence, contravenes the provisions of Article 84 of the GDPR, which states that sanctions must be "effective, proportionate, and dissuasive." It argues that the proposed sanction lacks effectiveness when the data controller has admitted the error and proceeded to correct it.
2. Regarding the non-compliance with Article 32 of the GDPR, it points out the security measures contained in the Report from its Information Systems Service, dated 10/03/2021, the implementation of which restricted access to the Document Registry, which was the root cause of the exfiltration of the document subject to the complaint; and notes that the AEPD has not taken these measures into account, which had already been adopted at the time the facts were acknowledged, and shifts to the present moment that lack of security measures that caused the breach without having conducted new inquiries.

On the other hand, it states that "zero risk" does not exist, as acknowledged by the AEPD itself, and cites what was stated by the Supreme Court in judgment no. 188/2022, from the Third Section of the Contentious-Administrative Chamber of the Supreme Court, dated February 15, when it states that "the obligation to adopt the necessary measures to guarantee the security of personal data cannot be considered an obligation of result, but of means. As a consequence of this obligation of means, the commitment acquired by the data controller is to adopt the technical and organizational means, as well as to deploy diligent activity in their implementation and use that tends to achieve the expected result with means that can reasonably be classified as suitable and sufficient for its achievement" (F.D.3º). It then describes other technical and organizational measures adopted since the events occurred, which are included among those mentioned in the Established Fact Fifth.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/19

3. Acknowledges the leakage of the information subject to the claim, explicitly stating that "this objective fact cannot be contested." However, it reminds that the duty of confidentiality of the individuals involved in the improper leakage of information (...) is imposed on them by Article 5.5 of Organic Law 2/1986, of March 13, on Security Forces and Bodies; and that, on 13/09/2021, the ***POSITION.1 sent an informative note expressly reminding this obligation.

4. The responding party considers that the acknowledgment of the data leakage incident, even before the claiming party, and the ongoing effort it has been making to improve technical and organizational measures to prevent further breaches of the confidentiality of personal data should be taken into account to resolve the procedure with the filing of the proceedings.

SEVENTH: On 15/09/2023, the instructor of the procedure proposed a resolution whereby the Director of the Spanish Agency for Data Protection imposes a warning sanction on the entity AYUNTAMIENTO DE GIJÓN for each of the following infractions:

- for the infringement of Article 32 of the GDPR, classified under Article 83.4.a) of the aforementioned GDPR, and qualified as serious for the purposes of prescription in Article 73.f) of the LOPDGDD.
- for the infringement of Article 5.1.f) of the GDPR, classified under Article 83.5.a) of the aforementioned GDPR, and qualified as very serious for the purposes of prescription in Article 72.1.a)

of the LOPDGDD.

EIGHTH: The aforementioned proposal for resolution was notified to the responding entity on the same date of 15/09/2023, through the Single Authorized Electronic Management Service (DEHÚ). In this notification letter, the entity was granted a period to submit allegations, which has elapsed without any written submission being received by this Agency.

From the actions taken in the present procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: On 20/01/2021, the claiming party submitted a document to the Electronic Registry of the AYUNTAMIENTO DE GIJÓN informing about the possible commission of an infraction of the disciplinary regime of the Local Police. This document contains the data relating to the name and surname of the person allegedly responsible for the infraction of the disciplinary regime and the details of the person submitting this document on behalf of the claiming party (name, surname, ID number, and position held in the organization of the claiming party).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/19

SECOND: On 19/02/2021, the claiming party submitted a new document to the same CITY COUNCIL to report the unlawful dissemination of the document mentioned in Proven Fact One through the messaging platform WhatsApp. In this document, they request that the illegitimate accesses to that document be verified and that its dissemination be investigated.

THIRD: By means of a document dated 30/08/2021, the CITY COUNCIL OF GIJÓN responded to the claiming party regarding their complaint dated 19/02/2021, referenced in Proven Fact Two. In this document, the content of which is summarized in Background One, which is declared reproduced in this act for evidentiary purposes, the aforementioned CITY COUNCIL informs the claiming party about the results of the verifications carried out by its Information Systems Service regarding the reported facts, of which the following are noteworthy:

- It confirms the accesses to the General Registry of the CITY COUNCIL OF GIJÓN (...), to the corresponding registration entry of the document mentioned in Proven Fact One; that (...) they have a user account that allows them remote access “to the common module of the general entry book of documents of the City Council”; and that this permission was justified by “the ordinary performance of the tasks of their job positions or (...).
- According to the report, (...) they declared having knowledge of the dissemination of the document mentioned in Proven Fact One through two WhatsApp groups (...), but denied having participated in this fact.
- It is added in the report that the representative of the claiming party provided evidence of the dissemination of the complete document in “pdf” format through one of those WhatsApp groups (...).
- Regarding the causes of the security incident and the measures adopted in this regard, the repeated report from the Information Systems Service indicates the following:

“Regarding the configuration of user accounts for the applications: for the user accounts involved in the security incident, permissions associated with them that should no longer be in place due to changes in the person's workplace or functions have been removed.

In the configuration of access to the General Registry: the possibility of consulting the documents associated with all the entries in the general entry book of the City Council has been deactivated. This consultation option was associated with a significant number of people, who had requested it since 2015 to the present and was necessary to work correctly with the files under their responsibility.

In this regard, it is noted that the measure to limit generalized access to the common module of the entry registry has not affected the performance of the usual tasks of the job positions under investigation.”

FOURTH: The CITY COUNCIL OF GIJÓN provided the list of employees who accessed the document mentioned in Proven Fact One during the period between its submission in the General Registry and

its dissemination. This list details the ID numbers of the individuals who accessed the document, their names, surnames, and the department to which they belong (...).

FIFTH: During the processing of the complaint that has given rise to these proceedings, the CITY COUNCIL OF GIJÓN informs this Agency that it has resolved to adopt additional complementary technical and organizational measures:

- Modify the process for hiring, terminating, and transferring municipal personnel in the assignment of accounts, permissions, or access authorizations, revocation, or deactivation of applications and IT and electronic resources, taking into account the functions and tasks they effectively perform in their job positions within the organization;
- Regulatory, technical, and training measures deemed appropriate regarding the existence, creation, and use of messaging groups, social networks, or internal communication of municipal personnel.
- Issue an Instruction from the Mayor's Office regulating access and authorization for the use of municipal information systems.
- Hire external assistance regarding information security.
- Establish breach management procedures; approve a security policy; establish an information security and personal data protection committee; and establish security procedures, approved by the same Committee, for the management of third-party copies (external services), certificates (cryptographic keys), risk analysis, information classification, document management, media deletion, and technical instructions for metadata cleaning and media encryption.

(...)

LEGAL GROUNDS

I

Competence

By virtue of the powers granted to each Supervisory Authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and according to the provisions of Articles 47, 48.1, 64.2, and 68.1 of the LOPDGDD, the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Obligation breached. Data security

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/19

The reported facts materialize in the access by third parties not involved to a document submitted by the claiming party to the responding party, through the Electronic Registry, violating the regulations regarding data protection. The document in question was subsequently disseminated through an instant messaging application.

The security of personal data is regulated in Articles 32, 33, and 34 of the GDPR.

Article 32 of the GDPR, "Security of processing," establishes the following:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying likelihood and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which shall include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

- c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law.”

The GDPR defines personal data breaches as “all breaches of security that result in the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data.”

It should be noted that the GDPR does not establish a list of security measures that are applicable according to the data being processed, but rather establishes that the controller and the processor shall implement technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of likelihood and severity to the rights and freedoms of the data subjects.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/19

Likewise, the security measures must be adequate and proportionate to the detected risk, indicating that the determination of technical and organizational measures should be made taking into account: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification process (which is not an audit), evaluation, and assessment of the effectiveness of the measures.

In any case, when assessing the adequacy of the level of security, particular attention shall be paid to the risks presented by the processing of data, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

In this same regard, Recital 83 of the GDPR states that:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the inherent risks of the processing and apply measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected.

When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, particularly susceptible to causing physical, material, or immaterial harm.”

In this case, the documentation in the file provides sufficient evidence of a breach of Article 32.1 of the GDPR by the respondent party, caused by a lack of security measures that allowed access by its employees to all documents submitted in the Electronic Registry of the entity, including those unrelated to the functions assigned to them. Access to the documents obviously entailed access to the personal information contained therein.

In this regard, from the information provided by the respondent entity itself, which is included in a

report on the incident prepared by its Information Systems Service, it follows that the Entry Register of documents of this entity could be accessed without restriction by a large number of people, even if the matter to which the document in question corresponded was not related to specific actions or functions assigned to such persons. It is even stated that there were access permissions to the information of that Register associated with persons who had changed their workplace or functions.

Evidence of the detected security deficiencies are the measures announced by the respondent party to prevent future incidents, which include the adoption of a new protocol “in the assignment of accounts, permissions, or access authorizations, revocation or deactivation of applications and IT and electronic resources, taking into account the functions and tasks that they actually perform in their positions.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/19

work in the organization.”

The CITY COUNCIL OF GIJÓN even claims that the measures adopted to limit generalized access to the common module of the Entry Register have not affected the performance of the usual tasks of the positions under investigation, which further confirms that the protocols implemented by this entity at the time the analyzed events took place were not adequate to guarantee data security and that such protocols were not justified by the performance of the functions assigned to the individuals who had permissions to access the aforementioned Register.

It is also noted that the document of the responding party accessed improperly, which informed about a possible infringement of the disciplinary regime of the Local Police, in addition to the factual circumstances that, in the opinion of the claiming party, determine the possible disciplinary infringement, included personal data relating to the name and surname of the possible infringer and the data of the representative of the claiming party relating to name, surname, ID number, and position held in the organization of the claiming party.

These facts demonstrate that the responding entity did not have the appropriate technical and organizational measures to guarantee the security and confidentiality of the data, especially those aimed at preventing access to the information by unauthorized third parties. This allowed several individuals within the organization to access the document submitted by the claiming party on 20/01/2021 in the Entry Register of the responding party, even though the functions assigned to these individuals were not related to the subject matter of the document in question.

In the Resolution of the Mayor's Office, dated 30/08/2021, regarding the legality of the verified accesses, it is stated as follows:

“From this, it can be concluded that some of the treatments expressed in the Background, such as habitual, general, or indiscriminate access to the entries of the entry register or for the exercise of supposed union rights, do not relate to the basis of legality and purposes contained in the aforementioned inventory of activities.”

Consequently, in accordance with the evidence presented, the aforementioned facts constitute a violation of the provisions of Article 32 of the GDPR, which gives rise to the application of the corrective powers that Article 58 of the aforementioned Regulation grants to the Spanish Data Protection Agency.

III

Unfulfilled obligation. Duty of confidentiality

On the other hand, Article 5 of the GDPR establishes the principles that must govern the processing of personal data and mentions, among them, the principle of “integrity and confidentiality”:

“1. Personal data shall be:

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

f) processed in such a way as to ensure an adequate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures (“integrity and confidentiality”).

(...).”

In accordance with the above-stated legal basis, the documentation in the proceedings provides sufficient evidence to understand that the responding party violated Article 5.1.f) of the GDPR, which regulates the duty of confidentiality, manifested in the access by unauthorized third parties to the personal data contained in the document submitted by the claiming party to the CITY COUNCIL OF GIJÓN, as noted in the First Established Fact.

This duty of confidentiality aims to prevent unauthorized leaks of data by the data subjects. In this case, the improper leakage of data has been acknowledged by the responding party.

Consequently, the aforementioned facts constitute a violation of the provisions of Article 5.1 f) of the GDPR, which gives rise to the application of the corrective powers that Article 58 of the aforementioned Regulation grants to the Spanish Data Protection Agency.

IV

Claims of the responding party

The CITY COUNCIL considers that the present sanctioning procedure lacks effectiveness, considering that it was initiated when this entity had already responded to the claiming party, the facts had been acknowledged, and measures had been adopted to prevent similar incidents, which have not been taken into account. It understands, for the same reasons, that the proceedings should be archived. However, this Agency does not share this approach, as it is appropriate to analyze and resolve what is necessary according to the factual situation subject to the claim. It is another matter to consider the reaction of the responding party to the reported facts regarding the obligation to adopt measures to adapt its actions to the regulations, which is analyzed in Legal Basis VII.

On the other hand, the responding party warns about what was stated by the Supreme Court in Judgment number 188/2022, dated February 15, regarding the nature of the obligation to adopt measures, according to which it cannot be an obligation of result, but of means. In this regard, it is important to emphasize that the infringement of Article 32 is not declared in this case due to the fact that the measures adopted by the CITY COUNCIL OF GIJÓN did not achieve the expected result, but due to the lack of adequate measures, as expressed in the preceding Legal Bases.

V

Classification and qualification of the infringements

The violation of Article 32 of the GDPR is classified in Article 83.4.a)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

of the cited GDPR in the following terms:

“4. The infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total global annual turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor pursuant to Articles 8, 11, 25 to 39, 42, and 43. (...).”

For its part, the LOPDGDD in its Article 71, Infringements, states that:

“Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

And in its Article 73, for the purposes of prescription, qualifies as “Infringements considered serious”:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following infringements

are considered serious and shall prescribe after two years, which involve a substantial violation of the articles mentioned therein, and in particular, the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.

(...)”.

On the other hand, non-compliance with the provisions of Article 5.1 f) of the GDPR constitutes an infringement classified under paragraph 5.a) of Article 83 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides the following:

“5. The infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total global annual turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent pursuant to Articles 5, 6, 7, and 9.”

For the purposes of the prescription period, Article 72 of the LOPDGDD indicates:

“Article 72. Infringements considered very serious.

1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall prescribe after three years, which involve a substantial violation of the articles mentioned therein, and in particular, the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679.”

VI

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/19

Corrective powers

In the event of an infringement of the provisions of the GDPR, among the corrective powers available to the Spanish Data Protection Agency, as the supervisory authority, Article 58.2 of said Regulation provides for the following:

“2 Each supervisory authority shall have all of the following corrective powers indicated below:

(...)

b) issue a warning to any controller or processor when the processing operations have infringed the provisions of this Regulation;

(...)

d) order the controller or processor to bring processing operations into compliance with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time;

(...)

i) impose an administrative fine in accordance with Article 83, in addition to or instead of the measures mentioned in this paragraph, depending on the circumstances of each particular case;.”

VII

Proposal for sanction

Article 83 “General conditions for the imposition of administrative fines” of the GDPR in its paragraph 7 establishes:

“Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State.”

Likewise, Article 77 “Applicable regime for certain categories of controllers or processors” of the LOPDGDD, in its wording in force at the time of the events that led to the complaint that motivated the

proceedings, provides the following:

"1. The regime established in this article shall apply to the processing for which they are responsible or for which they are processors:

(...)

c) The General Administration of the State, the Administrations of the autonomous communities, and the entities that make up the Local Administration.

(...)

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or correct the effects of the infringement that has been committed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/19

The resolution will be notified to the person responsible or in charge of the processing, to the body to which they hierarchically depend, if applicable, and to the affected parties who had the status of interested parties, if applicable.

3. Without prejudice to what is established in the previous section, the data protection authority will also propose the initiation of disciplinary actions when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied will be those established in the legislation on disciplinary or sanctioning regimes that are applicable.

Furthermore, when the infringements are attributable to authorities and executives, and the existence of technical reports or recommendations for the processing that have not been duly addressed is proven, the resolution imposing the sanction will include a reprimand naming the responsible position and will order publication in the Official State Gazette or the corresponding regional gazette.

4. The resolutions related to the measures and actions referred to in the previous sections must be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article will be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities.

6. When the competent authority is the Spanish Agency for Data Protection, it will publish on its website, with due separation, the resolutions related to the entities mentioned in section 1 of this article, with an explicit indication of the identity of the person responsible or in charge of the processing who committed the infringement.

When the competence corresponds to an autonomous data protection authority, the publicity of these resolutions will be subject to what its specific regulations provide.

This provision excludes the imposition of administrative fines when the infringements referred to in articles 72 to 74 of the LOPDGDD are committed by the categories of responsible persons or in charge of the processing listed in section 1 of the aforementioned article 77, establishing that the procedures arising from violations of personal data protection regulations committed by those entities will be resolved by imposing a warning sanction on the infringing entity.

It is also contemplated that the resolution issued may establish the measures that should be adopted to cease the conduct, correct the effects of the infringement that has been committed, and carry out the necessary adjustments, in this case, to the requirements set forth in articles 32 and 5.1.f) of the GDPR, as well as the provision of evidence of compliance with the requirements.

Thus, in accordance with the provisions of the aforementioned article 77 of the LOPD, the responsible entity (CITY COUNCIL OF GIJÓN) may be required to adjust its actions to the personal data protection regulations, to the extent expressed in the previous Legal Grounds.

In this case, however, it is recorded in the proceedings that the party being claimed, subsequent to the facts subject to the proceedings, adopted measures aimed at preventing indiscriminate access to the entries of the Entry Register by parties.

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
18/19

of its employees, having established new protocols in the configuration of user accounts for the applications, removing permissions and deactivating the possibility of consulting the documents associated with all entries in the general entry book of the CITY COUNCIL; as well as for the processes of registering individuals in the organization, collecting the accesses, technical resources, and authorizations that must be assigned, protocols for deactivation of user accounts, and protocols for modification of individuals due to changes in position or functions.

Based on this, it is not deemed necessary in this case to order the responding party to adopt new measures in addition to those already implemented.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on the CITY COUNCIL OF GIJÓN, with NIF P3302400A, a warning sanction for the following infractions:

- for the infringement of Article 32 of the GDPR, classified under Article 83.4.a) of the aforementioned GDPR, and qualified as serious for the purposes of prescription in Article 73.f) of the LOPDGDD.
- for the infringement of Article 5.1.f) of the GDPR, classified under Article 83.5.a) of the aforementioned GDPR, and qualified as very serious for the purposes of prescription in Article 72.1.a) of the LOPDGDD.

SECOND: NOTIFY this resolution to the CITY COUNCIL OF GIJÓN.

THIRD: COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Administrative Litigation Chamber of the National Court, in accordance with the provisions of Article 25 and in section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Administrative Litigation Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

19/19

If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency is not aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension to be concluded.

938-250923

Mar España Martí
Director of the Spanish Agency for Data Protection
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es